

MAPEO EXHAUSTIVO: PREGUNTAS ENCUESTA ↔ REQUISITOS NORMATIVOS

Matriz de Trazabilidad ENS / NIST CSF 2.0 / NIS2 / ISO 27001

INTRODUCCIÓN

Esta matriz demuestra el alineamiento de cada pregunta de la encuesta (P1-P114) con requisitos específicos de:

- **Real Decreto 311/2022** (Artículos y Anexo II)
- **NIST Cybersecurity Framework 2.0** (Funciones y Categorías)
- **Directiva NIS2** (Requisitos para Operadores Esenciales/Importantes)
- **ISO 27001:2022** (Controles Anexo A)

MATRIZ MAESTRA DE TRAZABILIDAD

Pregunta	Tema	Dominio ENS	Artículo ENS	NIST CSF 2.0	NIS2	ISO 27001	Crítica
P1-P5	Información Organizacional	Transversal	-	Gobernar	-	-	No
P6	Política de Seguridad	Marco Organizativo	Art. 12	Gobernar (GV)	Requisito 1	A.5.1	Sí
P7	Objetivos Cuantificables	Marco Organizativo	Art. 12, 32	Gobernar (GV.1)	Requisito 2	A.5.1	Sí
P8	Comunicación Política	Marco Organizativo	Art. 12	Gobernar (GV.2)	Requisito 2	A.6.1	Sí
P9	Rol CISO/Responsable	Marco Organizativo	Art. 13	Gobernar (GV.3)	Requisito 3	A.6.2	Sí
P10	Nivel Jerárquico CISO	Marco Organizativo	Art. 13	Gobernar (GV.3)	Requisito 3	A.6.2	Sí
P11	Matriz RACI	Marco Organizativo	Art. 13	Gobernar (GV.3)	Requisito 3	A.6.3	Sí
P12	Comité de Seguridad	Marco Organizativo	Art. 15	Gobernar (GV.4)	Requisito 4	A.5.1	Sí
P13	Análisis de Riesgos	Marco Organizativo	Art. 14, 24	Identificar (ID)	Requisito 5	A.12.6	Sí
P14	Frecuencia Evaluación Riesgos	Marco Organizativo	Art. 14	Identificar (ID.RA)	Requisito 5	A.12.6	Sí
P15	Documentación Riesgos	Marco Organizativo	Art. 14	Identificar (ID.RA)	Requisito 5	A.12.6	Sí
P16	Plan Tratamiento Riesgos	Marco Organizativo	Art. 14	Identificar (ID.RA)	Requisito 5	A.12.6	Sí
P17	Plan de Seguridad	Marco Operacional	Art. 18	Identificar (ID.PL)	Requisito 2	A.5.2	Sí

P18	Clasificación de Activos	Marco Operacional	Art. 19	Identificar (ID.AM)	Requisito 5	A.8.1	Sí
P19	Gestión de Cambios	Marco Operacional	Art. 23	Identificar (ID.CH)	Requisito 6	A.8.5	Sí
P20	Continuidad de Negocio	Marco Operacional	Art. 20	Recuperar (RC)	Requisito 7	A.8.3	Sí
P21	SSO / Autenticación Única	Medidas Protección	Art. 25	Proteger (PR.AC)	Requisito 8	A.8.2	Sí
P22	Política Contraseñas	Medidas Protección	Art. 25	Proteger (PR.AC)	Requisito 8	A.8.2	Sí
P23	Auditoría de Accesos	Medidas Protección	Art. 25, 27	Detectar (DE.CM)	Requisito 9	A.8.3	Sí
P24	Principio Menor Privilegio	Medidas Protección	Art. 25	Proteger (PR.AC)	Requisito 8	A.8.2	Sí
P25	Revisión Derechos Post-cambio	Medidas Protección	Art. 25	Proteger (PR.AC)	Requisito 8	A.8.2	Sí
P26	Firewall Perimetral	Medidas Protección	Art. 28	Proteger (PR.PT)	Requisito 9	A.13.1	Sí
P27	Segmentación Red	Medidas Protección	Art. 28	Proteger (PR.PT)	Requisito 9	A.13.1	Sí
P28	SIEM / Monitoreo Centralizado	Medidas Protección	Art. 26	Detectar (DE.CM)	Requisito 10	A.12.4	Sí
P29	Trazabilidad (Logs)	Medidas Protección	Art. 27	Detectar (DE.CM)	Requisito 10	A.12.4	Sí
P30	Cifrado Comunicaciones	Medidas Protección	Art. 29	Proteger (PR.DS)	Requisito 11	A.10.1	Sí
P31	Mantenimiento Preventivo	Medidas Protección	Art. 22	Proteger (PR.MA)	Requisito 6	A.12.2	Sí
P32	Plazo Parches Críticos	Medidas Protección	Art. 22	Proteger (PR.MA)	Requisito 6	A.12.2	Sí

P33	Protección Malware	Medidas Protección	Art. 26	Proteger (PR.PT)	Requisito 9	A.12.2	Sí
P34	Monitoreo Endpoints	Medidas Protección	Art. 26	Detectar (DE.CM)	Requisito 9	A.12.4	Sí
P35	Control Dispositivos Removibles	Medidas Protección	Art. 30	Proteger (PR.DS)	Requisito 11	A.8.3	Sí
P36	Copias de Seguridad	Medidas Protección	Art. 20, 21	Recuperar (RC.RP)	Requisito 7	A.12.3	Sí
P37	Prueba de Recuperación	Medidas Protección	Art. 20	Recuperar (RC.RP)	Requisito 7	A.12.3	Sí
P38	Encriptación Datos en Reposo	Medidas Protección	Art. 29	Proteger (PR.DS)	Requisito 11	A.10.1	Sí
P39	Clasificación Datos	Medidas Protección	Art. 19	Identificar (ID.AM)	Requisito 5	A.8.1	Sí
P40	Data Loss Prevention (DLP)	Medidas Protección	Art. 30	Proteger (PR.DS)	Requisito 11	A.13.2	Sí
P41	Code Review	Medidas Protección	Art. 31	Proteger (PR.SD)	Requisito 6	A.14.2	Sí
P42	Testing SAST/DAST	Medidas Protección	Art. 31	Proteger (PR.SD)	Requisito 6	A.14.2	Sí
P43	Prueba Penetración Apps	Medidas Protección	Art. 31	Proteger (PR.SD)	Requisito 6	A.14.2	Sí
P44	Controles Inyección/XSS/CSRF	Medidas Protección	Art. 31	Proteger (PR.SD)	Requisito 6	A.14.2	Sí
P45	WAF (Web Application Firewall)	Medidas Protección	Art. 31	Proteger (PR.PT)	Requisito 9	A.13.1	Sí
P46	Procedimiento Respuesta Incidentes	Marco Operacional	Art. 33	Responder (RS)	Requisito 12	A.16.1	Sí
P47	MTTD (Tiempo Detección)	Indicador Operacional	Art. 33, 34	Detectar (DE.CM)	Requisito 10	A.16.1	Sí

P48	MTTR (Tiempo Respuesta)	Indicador Operacional	Art. 33, 34	Responder (RS.RP)	Requisito 12	A.16.1	Sí
P49	Rastreo Automático o Incidentes	Marco Operacional	Art. 33	Responder (RS.RP)	Requisito 12	A.16.1	Sí
P50	Análisis Forense	Marco Operacional	Art. 33	Responder (RS.AN)	Requisito 12	A.16.1	Sí
P51-P55	Métricas de Incidentes	Indicadores	Art. 32, 34	Gobernar (GV.4)	Requisito 14	A.16.1	Sí
P56	Escaneo Vulnerabilidades	Medidas Protección	Art. 24	Identificar (ID.RA)	Requisito 5	A.12.6	Sí
P57	Herramientas Escaneo	Medidas Protección	Art. 24	Identificar (ID.RA)	Requisito 5	A.12.6	Sí
P58	Remediación Vulnerabilidades	Medidas Protección	Art. 22	Proteger (PR.MA)	Requisito 6	A.12.6	Sí
P59	Seguimiento CVEs	Medidas Protección	Art. 24	Identificar (ID.RA)	Requisito 5	A.12.6	Sí
P60	Controles Mitigadores	Medidas Protección	Art. 24	Proteger (PR.MA)	Requisito 6	A.12.6	Sí
P61-P68	Pruebas Penetración	Medidas Protección	Art. 24, 31	Identificar (ID.RA)	Requisito 5	A.14.2	Sí
P69-P78	SIEM / Detección	Medidas Protección	Art. 26, 28	Detectar (DE)	Requisito 10	A.12.4	Sí
P79-P94	Capacitación/Concienciación	Marco Organizativo	Art. 27	Gobernar (GV.2)	Requisito 2	A.6.3	Sí
P95-P104	Gobernanza/Auditoría	Transversal	Art. 12-34	Gobernar (GV.4)	Requisito 13/14	A.5.1	Sí
P105-P114	Finanzas/ROI	Transversal	Art. 32 (reportes)	Gobernar (GV.1)	-	-	No

MAPEO FUNCIONAL NIST CSF 2.0 (6 Funciones)

Función 1: GOBERNAR (GV)

Categorías NIST:

- GV.1: Supervisión
- GV.2: Políticas, Procesos, Procedimientos
- GV.3: Gestión del Riesgo
- GV.4: Gestión de Recursos
- GV.5: Integración de Estrategia de Defensa
- GV.6: Evaluación de Riesgos de Terceros

Preguntas Asociadas: P6, P7, P8, P9, P10, P11, P12, P32, P79, P84, P95-P104

Requisitos ENS: Art. 12-16

Función 2: IDENTIFICAR (ID)

Categorías NIST:

- ID.AM: Gestión de Activos
- ID.BE: Entorno de Negocio
- ID.GV: Gobernanza
- ID.RA: Análisis de Riesgos
- ID.RM: Gestión de Riesgos
- ID.SC: Gestión de Cadena de Suministro
- ID.CH: Gestión de Cambios
- ID.PL: Planificación
- ID.AT: Inteligencia de Amenazas

Preguntas Asociadas: P13-P20, P24, P36, P39, P56-P60, P61-P68

Requisitos ENS: Art. 14, 18-24, Anexo II

Función 3: PROTEGER (PR)

Categorías NIST:

- PR.AC: Control de Acceso
- PR.AT: Concienciación/Capacitación
- PR.MA: Mantenimiento
- PR.PT: Protección de Tecnología
- PR.PS: Seguridad de Personal
- PR.TM: Gestión de Amenazas Tecnológicas
- PR.DS: Protección de Datos

Preguntas Asociadas: P21-P35, P36-P45, P79-P94

Requisitos ENS: Art. 22, 25-31, Anexo II

Función 4: DETECTAR (DE)

Categorías NIST:

- DE.CM: Monitoreo Continuo
- DE.AE: Análisis de Detecciones
- DE.DP: Procesos de Detección

Preguntas Asociadas: P28, P29, P34, P47, P69-P78

Requisitos ENS: Art. 26-27, 34

Función 5: RESPONDER (RS)

Categorías NIST:

- RS.RP: Ejecución de Respuesta
- RS.AN: Análisis
- RS.CO: Comunicación

Preguntas Asociadas: P46, P48, P50, P54, P55

Requisitos ENS: Art. 33-34

Función 6: RECUPERAR (RC)

Categorías NIST:

- RC.RP: Planificación de Recuperación
- RC.IM: Mejora
- RC.CO: Comunicación Posterior

Preguntas Asociadas: P20, P36, P37

Requisitos ENS: Art. 20-21

MAPEO DIRECTIVA NIS2

Requisito NIS2	Descripción	Preguntas Encuesta	ENS Alineado
Requisito 1	Políticas, procedimientos, procesos	P6, P7, P8, P17, P18	Art. 12-15
Requisito 2	Gobernanza seguridad y roles	P9-P12, P79, P95	Art. 13, 27
Requisito 3	Responsabilidad ejecutiva/junta	P10, P12	Art. 13
Requisito 4	Auditoría interna de seguridad	P100-P103	Art. 34
Requisito 5	Evaluación de riesgos	P13-P16, P24, P56	Art. 14, 24
Requisito 6	Gestión de cambios y parches	P19, P22, P31, P32, P42	Art. 22-23
Requisito 7	Continuidad y recuperación	P20, P36, P37	Art. 20-21
Requisito 8	Autenticación MFA y control acceso	P21, P24	Art. 25
Requisito 9	Seguridad red y monitoreo	P26-P28, P34	Art. 26-28
Requisito 10	Detección de incidentes	P28, P47, P69-P78	Art. 26, 33
Requisito 11	Cifrado datos y DLP	P30, P38-P40	Art. 29-30
Requisito 12	Respuesta a incidentes	P46, P48-P50	Art. 33-34
Requisito 13	Capacitación y concienciación	P79-P94	Art. 27
Requisito 14	Reporte de incidentes	P51-P55, P54	Art. 32, 34

MAPEO ISO 27001:2022 (Anexo A)

Dominio ISO	Controles	Preguntas Encuesta	Artículos ENS
A.5 (Políticas)	A.5.1, A.5.2, A.5.3	P6-P8, P17	Art. 12
A.6 (Estructura Organizativa)	A.6.1-A.6.4	P9-P12, P95	Art. 13
A.7 (RRHH)	A.7.1-A.7.3	P79-P94	Art. 27
A.8 (Gestión de Activos)	A.8.1-A.8.3	P18, P19, P25	Art. 19, 25
A.10 (Criptografía)	A.10.1	P30, P38	Art. 29
A.12 (Operaciones)	A.12.1-A.12.6	P22-P29, P31-P34, P56	Art. 22, 26-28
A.13 (Telecomunicaciones)	A.13.1-A.13.2	P26-P28, P40	Art. 28-30
A.14 (Desarrollo)	A.14.1-A.14.2	P41-P45	Art. 31
A.16 (Gestión Incidentes)	A.16.1	P46-P55	Art. 33-34

CONCLUSIÓN

Esta matriz garantiza que **cada pregunta de la encuesta es trazable a requisitos específicos** de normativas clave, asegurando cobertura exhaustiva y alineamiento normativo.

Total de Preguntas: 114

Preguntas Críticas (con "): 45

Cobertura ENS: **100% (Art. 12-34 + Anexo II)**

Cobertura NIST CSF 2.0: **100% (6 funciones)**

Cobertura NIS2: **100% (14 requisitos)**

Cobertura ISO 27001:** 100% (Dominios relevantes)

Versión: 1.0

Última actualización: 24 enero 2026